AIORI HACKATHON 2026 // PROBLEM STATEMENT PS-011

ArgusASM: Autonomous Attack-Surface Inventory & Drift Sentinel

Level 2 Technical Submission Dossier & Architecture Specification

Track: Cybersecurity & Infrastructure Resilience | **Team:** ZeroDayZ | **Repo:** aiori-hackathon/A3-PS011-TC116
Authorization Ref: AIORI-2026-PS011-AUTH-001 | **Evaluation Window:** 16 Oct - 30 Oct 2026 | **Version:** 1.0 (Submission Freeze)

Official Submission Deliverables & Verification Matrix

Deliverable	Live Link / Location	Verification Scope & Purpose
Live Working Demo	https://a3-ps-011-tc-116.vercel.app	Production Sentinel Web Console (Interactive HUD, topology graph, drift viewer, Dark/Light mode)
Walkthrough Video	https://youtu.be/rFjD-Qt4ju8?si=UlPgNCL80PGyVgLd	Complete video demonstration covering perimeter discovery, drift injection, and verification
Presentation Deck	Google Slides Presentation	High-level architecture, threat modeling, and defensive engineering approach
Live Backend API	https://argus-backend-api-sqrs.onrender.com	FastAPI REST API, Swagger UI (/docs), and live telemetry (/api/telemetry/live)
Executive Audit Report	.../api/v1/export/executive-report	Print-ready executive perimeter report with cryptographic Merkle attestation
OASIS SARIF 2.1.0	.../api/v1/export/sarif	OASIS standard security format for GitHub Advanced Security and enterprise SIEMs
Automated Pytest Suite	tests/ (51/51 tests passing)	100% pass rate in 1.1s covering scope caps, 0-packet ledger, Merkle chain, wording lint
Offline Deliverable Pack	samples/	Snapshots (T0/T1/T2), drift reports, SARIF, CSV, JSON, and HTML executive audit report

Section 1: Title, Abstract, Authorized Scope Definition & Authorization Statement

1.1 Executive Abstract: Modern hybrid cloud architectures frequently suffer from asset accumulation debt: unmaintained test subdomains, expired X.509 TLS certificates, exposed debug ports, and orphaned CNAME records pointing to decommissioned third-party cloud buckets. **ArgusASM** is an autonomous, strictly non-intrusive external attack surface management (ASM) platform designed specifically for the AIORI 2026 PS-011 mandate. Operating under hard cryptographic guardrails, ArgusASM continuously discovers, inventories, and audits an authorized portfolio of public domains and hosts, establishing a tamper-evident baseline snapshot anchored in a SHA-256 Merkle tree. When perimeter drift occurs, ArgusASM triggers immediate multi-channel alerts, computes stateful set-difference deltas, applies CVSS-calibrated hygiene score deductions, and stages non-destructive remediation advisories behind a mandatory Human-in-the-Loop (HITL) governance gate.

1.2 Authorized Scope Boundary: Enforces an un-bypassable boundary cap of maximum 20 public domains and maximum 10 public hosts. Probing beyond these limits is blocked at the pre-flight parser level with zero network packets dispatched.

- **Primary Zone:** aiori.lab (Authoritative CoreDNS Lab Zone)
- **Approved Domain Cap:** 20 (Active portfolio: 15 domains)
- **Approved Host Cap:** 10 (Active portfolio: 8 hosts)
- **Permitted Port Whitelist:** Strictly restricted to {22, 53, 80, 443, 8080}

1.3 Formal Authorization Statement: *'This document certifies that ArgusASM is authorized by AIORI Infrastructure & Security Operations to perform passive, read-only reconnaissance against the lab assets cataloged in approved_scope.json between 2026-10-01T00:00:00Z and 2026-11-30T23:59:59Z. Active exploitation, credential brute-forcing, denial-of-service, third-party cloud bucket claiming, and out-of-scope targeting are strictly prohibited.'*

Section 2: Architecture and the Four Documented Checks

ArgusASM decouples discovery, state tracking, and user visualization into clean asynchronous micro-modules:

- **Check 1 (Public DNS Inventory):** Resolves RFC 1035/2181 A, AAAA, CNAME, MX, TXT, and NS records with 3.0s socket timeouts. Traverses CNAME chains to a maximum depth of 3 hops. Read-only; zone transfers (AXFR) are prohibited.
- **Check 2 (Extended TLS Inspector):** Validates X.509 certificates (RFC 5280). Identifies expired certificates, near-term expirations (<14 days), self-signed certificates, weak RSA keys (<2048-bit), and deprecated protocols (TLS 1.0/1.1). Non-intrusive handshake only.
- **Check 3 (Permitted Service Auditor):** Connects strictly to whitelisted ports {22, 53, 80, 443, 8080}. Non-intrusively captures service banners without fuzzing. Detects unapproved shadow services (such as Werkzeug debug on port 8080).
- **Check 4 (Potential Dangling DNS Detector):** Analyzes CNAME targets against cloud provider patterns (AWS S3, Azure Web Apps, GitHub Pages). Flags unallocated buckets via HTTP 404 NoSuchBucket fingerprints. **Strict non-exploitation guarantee: Never attempts to claim or register orphaned resources.**

Section 3: Non-Exploitation Policy and Safety Guardrails

ArgusASM guarantees that defensive monitoring never introduces operational risk. Out-of-scope targets are rejected at pre-flight with strictly zero network calls, logged into SQLite by RequestLedger:


```
[ { "id": "REQ-7B8A91C2D4E0", "timestamp": "2026-10-25T13:21:40.104Z", "target": "external-attacker.com",
"probe_type": "DNS", "status": "ScopeViolation", "network_calls_made": 0, "duration_ms": 0.1,
"response_summary": "BLOCKED BY SCOPE GUARDRAIL: Target not in approved scope.", "authorization_ref":
"AIORI-2026-PS011-AUTH-001" } ]
```


Emergency Kill Switch (R_7): Invoking POST /api/v1/killswitch halts all in-flight probing threads within <10ms.
Human-in-the-Loop (HITL) Gate: All High and Critical findings require explicit human sign-off before any remediation script or firewall change can be dispatched.

Section 4: Stateful Change Detection, Snapshot Schema & Merkle Chain

Perimeter state is captured as versioned JSON snapshots (snapshots/T0.json, T1.json, T2.json). Each snapshot cryptographically embeds scope_sha256 (the SHA-256 hash of approved_scope.json) and a 32-byte SHA-256 Merkle root computed across all canonicalized asset records.

Merkle Hash Chain Linking: MerkleRoot_n = SHA256(Leaves_n || MerkleRoot_{n-1}). This mathematically guarantees that historical observations cannot be mutated retroactively without breaking the cryptographic chain.

Stateful Drift Delta Algorithm: Delta = Current \ Baseline. Categorizes 10 typed drift events: NEW_SERVICE, REMOVED_SERVICE, EXPIRED_CERT, CERT_EXPIRING, CERT_RESOLVED, DNS_RECORD_CHANGED, DANGLING_DNS_CANDIDATE, DANGLING_DNS_RESOLVED, ASSET_ADDED, ASSET_REMOVED. Employs a 2-observation confirmation rule to filter transient network jitter.

Section 5: Seeded-Issue Detection Results & Precision/Recall Metrics

Evaluated against the multi-container lab testbed simulating the 3 seeded faults:

Seed ID	Target Asset	Seeded Fault	Expected Detection	Observed Detection	Score Impact
TEST-SEED-01	legacy.aiori.lab:443	Expired TLS Certificate	EXPIRED_CERT	**DETECTED (100%)**	-35 points
TEST-SEED-02	dev-edge.aiori.lab:8080	Unauthorized Port 8080	NEW_SERVICE	**DETECTED (100%)**	-25 points
TEST-SEED-03	test-s3.aiori.lab	Orphaned S3 CNAME	DANGLING_DNS	**DETECTED (100%)**	-30 points
Control Host A	api.aiori.lab:443	Healthy Production Host	Clean Posture	**0 False Positives**	0 deductions

Empirical Accuracy: Recall = 100.0% (3/3 seeded faults detected) | Precision = 100.0% (0 false positives on Control Host A)
Out-of-Scope Enforcement: 100.0% blocked with strictly 0 network calls | **HITL Governance:** 100.0% staged for operator review.

Section 6: False-Positive Analysis and Confidence Calibration

To prevent alert fatigue and score distortion, ArgusASM applies calibrated mitigation heuristics:

- **Wildcard DNS Zones:** Resolves random UUID subdomain. If active, domain is flagged WILDCARD_ACTIVE and generic DNS alerts are down-weighted to LOW confidence.
- **CDN / Reverse Proxy Detection:** Identifies Cloudflare/Akamai/Fastly headers (Server/Via) and suppresses false port alerts.
- **Staging Self-Signed Handling:** Uses host role in approved_scope.json; downgrades staging self-signed certs to INFO.
- **Generic 404 vs Provider Error:** Requires provider-specific signature (<Code>NoSuchBucket</Code>); generic 404s receive LOW confidence.
- **Score Deduction Caps (R_3):** Expired TLS capped at -40 pts, open ports capped at -35 pts, dangling DNS capped at -40 pts. Hygiene Score: Baseline T0 = 96/100, Drifted T1 = 68/100, Remediated T2 = 96/100.

Section 7: Conclusion, Operational Impact, Limitations & Regional Roadmap

7.1 Operational Impact: ArgusASM transforms attack surface inventory from an ad-hoc scanning exercise into a continuous, deterministic, and cryptographically provable sentinel. By combining RFC-compliant passive inspection with SHA-256 Merkle provenance, enterprise security teams can eliminate shadow exposures with zero service disruption.

7.2 Stated Limitations: Passive inspection cannot confirm whether an unallocated cloud bucket is internally reserved by cloud providers. Scans are strictly bounded by approved_scope.json and do not execute internet-wide sweeps.

7.3 Delivered P2 Features & Regional Roadmap: All Level 2 differentiators are delivered and operational: automated SARIF v2.1.0 export, CSV spreadsheets, one-click executive HTML reports, passive Certificate Transparency monitor, and simulation controllers. For the regional finals (November 2026), the team will extend Post-Quantum Cryptography (PQC) readiness tracking (NIST FIPS 203/204) and distributed multi-cloud edge probe nodes.